

PROPOSAL PACKAGE | DOCUMENT 08

Security, Privacy and Governance

Access control, audit, data residency, GCC data protection compliance, AI governance and the human-in-the-loop guarantee

Document	08 of 15
Audience	Client CISO, legal and compliance, IT; delivery team
Version	1.0 (first-meeting edition)
Date	September 2026
Classification	Confidential - prepared for the client

Contents

1. Summary..... 3

2. Security architecture..... 3

 2.1 Identity and access..... 3

 2.2 Data protection in transit and at rest..... 3

 2.3 Application security..... 3

 2.4 Audit and non-repudiation..... 4

 2.5 Availability and resilience..... 4

3. Data residency and sovereignty..... 4

 3.1 The question the client will ask..... 4

 3.2 Deployment patterns..... 5

 3.3 Recommended approach..... 5

4. GCC data protection landscape (2026)..... 5

5. Privacy by design in the CRM..... 6

6. AI governance..... 6

7. Compliance roadmap by tier..... 7

8. Responsibilities..... 7

1. Summary

The platform is designed so that **the client owns everything** (accounts, code, data), **every action is attributable** (who saw what, who approved what), **data location is a policy choice** (managed cloud in a GCC region through fully sovereign hosting), and **no AI action reaches the outside world without a human** (outreach approval gate).

This document is not legal advice. It sets out the controls we will build and the regulatory landscape as we understand it in 2026, so that the client's legal and compliance teams can confirm the approach for their jurisdictions.

2. Security architecture

2.1 Identity and access

- Single sign-on through the client's identity provider (OpenID Connect); multi-factor authentication enforced there.
- Role-based access: executive, relationship manager, approver, analyst, administrator, auditor (read-only). Roles can be scoped to a category or business unit.
- Document-level access lists mirrored from the source (for example SharePoint permissions) or set on upload; enforced in the database with row-level security and applied before retrieval, so the model never sees a passage the user cannot read.
- Relationship-level ownership; managers see their portfolio, leadership sees all; configurable.
- Session timeouts, device and IP logging, administrative actions requiring re-authentication.

2.2 Data protection in transit and at rest

- TLS 1.2 or higher everywhere, including service-to-service calls.
- Encryption at rest for database, object storage and backups using provider-managed keys; customer-managed keys (KMS/Key Vault, HSM-backed) at enterprise tier.
- Secrets in a managed vault; never in code or configuration files; rotated.
- Anti-malware scanning of every uploaded file before parsing; parsers run in isolated workers with no outbound network access.

2.3 Application security

- Secure development lifecycle: code review, dependency scanning, container scanning, static analysis in CI; signed images in production.
- OWASP ASVS-aligned controls: input validation, output encoding, CSRF protection, rate limiting, security headers.
- Prompt-injection defence for the assistant: retrieved document text is delimited and treated as data; system instructions are not overridable by document content; suspicious instruction-like passages are flagged at ingestion.
- Annual third-party penetration test; findings tracked to closure.

2.4 Audit and non-repudiation

- Append-only audit table with hash chaining: each event stores the hash of the previous event, and the chain is anchored daily (for example to object storage with object lock). Tampering is detectable.
- Events recorded: login, document view, question asked (with retrieved passages and answer), finding created or resolved, record created or changed, stage change, outreach draft, submission, approval or rejection, send, connector sync, configuration change, export.
- Auditor role with read-only access and export to the client's SIEM at enterprise tier.

2.5 Availability and resilience

- Automated backups with point-in-time recovery; cross-region copies at enterprise tier; quarterly restore tests.
- Defined RTO and RPO per tier (Document 03, section 11).
- Health checks, alerting, on-call rota at enterprise tier.

3. Data residency and sovereignty

3.1 The question the client will ask

"Where does our data go?" The honest answer has two parts: **data at rest** (documents, database, backups) and **data in processing** (what the AI model sees while answering).

- Data at rest can be kept in a GCC cloud region from day one (AWS UAE me-central-1, AWS Bahrain me-south-1, Azure UAE North, Google Cloud Dammam) or on premises.
- Data in processing depends on the model route. As of early 2026, Claude models are reachable from the AWS Middle East regions through Amazon Bedrock's **global cross-region inference**, which may process the request outside the region in transit, encrypted, without storage, under AWS enterprise terms. Microsoft Foundry's Claude deployments are "Global Standard". Google Cloud's Claude endpoints are US and EU multi-region. Frontier models with an in-country endpoint in the GCC were not confirmed at the time of writing; this should be re-checked at discovery because availability changes quickly.
- For processing that must stay in country, the platform routes to open-weight models hosted on in-region GPUs (Pattern C), at a cost and quality trade-off documented in Document 03 and Document 05.

3.2 Deployment patterns

Where the data and the AI model live: three deployment patterns

PATTERN A - Cloud, managed AI	PATTERN B - Hybrid by classification	PATTERN C - Fully sovereign
Documents & database stored in a GCC cloud region (UAE / Bahrain / KSA). AI inference via a frontier model API (Claude via AWS Bedrock cross-region, Anthropic API, Microsoft Foundry). Fastest, cheapest, highest AI quality. Prompts may be processed outside the GCC in transit (encrypted, not stored by the provider under enterprise terms).	Same as A for internal / non-sensitive documents. Documents tagged 'restricted' or containing personal data are routed only to an in-region model. Best balance for most GCC groups. Requires a document classification step at ingestion (we build it in).	Everything, including the AI model, runs on GPUs inside the country (cloud region or private data centre). Open-weight models (e.g. Qwen 3.5, GLM-5, Gemma 4) served with vLLM. Highest control and compliance. Higher fixed cost; model quality slightly behind frontier APIs; needs GPU ops.

The model gateway makes the pattern a configuration choice, not a rebuild: the same application code talks to any model.
Recommendation: start on Pattern A for the demo, design for B, keep C as a documented upgrade path.

Deployment patterns

3.3 Recommended approach

Classify documents at ingestion (public, internal, confidential, restricted) and personal-data status. Route by policy: restricted and personal-data documents to in-region processing; everything else to the frontier model. This delivers most of the quality at most of the compliance, and is a configuration setting in the model gateway.

4. GCC data protection landscape (2026)

Jurisdiction	Primary law and regulator	Points relevant to this project
Saudi Arabia	Personal Data Protection Law (PDPL), in force September 2023, enforcement from September 2024; Saudi Data and AI Authority (SDAIA). Regulation on Personal Data Transfer Outside the Kingdom; SDAIA Risk Assessment Guideline for cross-border transfers (February 2025).	Cross-border transfer of personal data requires a lawful mechanism (adequacy, standard contractual clauses or binding corporate rules, or exceptions) and a documented risk assessment for large-scale or sensitive transfers. Data of Saudi residents in the CRM should be stored in Kingdom or transferred under an approved mechanism. Active enforcement decisions have been issued.
UAE (onshore)	Federal Decree-Law No. 45 of 2021 on Personal Data Protection, in force 2 January 2022; UAE Data Office.	GDPR-like duties: lawful basis, purpose limitation, data subject rights, breach notification, DPO for high-risk processing. Cross-border transfer permitted to adequate jurisdictions or with safeguards.
UAE free zones	DIFC Data Protection Law No. 5 of 2020 (DIFC Commissioner of Data Protection); ADGM Data	Separate regimes for entities established in the zones; closely modelled on GDPR; require

Jurisdiction	Primary law and regulator	Points relevant to this project
	Protection Regulations 2021 (ADGM Office of Data Protection).	records of processing and, for DIFC, notification of automated decision tools in some cases.
Qatar	Law No. 13 of 2016 on Personal Data Privacy Protection; guidelines 2021; Compliance and Data Protection Department (MCIT). QFC has its own regulations.	Consent and purpose rules; sensitive data requires prior permission.
Bahrain	Personal Data Protection Law No. 30 of 2018 with implementing ministerial resolutions; Personal Data Protection Authority.	Transfers permitted to listed adequate countries or with authority approval; data protection guardian requirement in some cases.
Oman	Personal Data Protection Law (Royal Decree 6/2022), full effect February 2026 after grace period.	Consent-centric; sensitive data permits; notification duties.
Kuwait	No comprehensive statute; sector rules (telecoms data privacy regulation, e-transactions law).	Contractual and confidentiality obligations govern.

Because the client's relationships span the GCC, the CRM stores each person's jurisdiction, consent status and source, so that outreach and transfer rules can be applied per record.

5. Privacy by design in the CRM

- Lawful basis and consent captured per contact (with source and date); outreach to contacts without recorded consent is flagged for the approver.
- Data minimisation: only fields the business needs; free-text notes are visible to the record owner and roles you configure.
- Retention policies per category; deletion and anonymisation routines; support for data-subject access and erasure requests with an audit record.
- Personal data of individuals is separable from corporate data, so sovereign routing can be applied to it specifically.

6. AI governance

Control	Implementation
Closed domain	System instruction and grounding check prohibit outside knowledge; refusal when evidence is absent
Explainability	Every answer shows its sources and pages; every finding shows both conflicting quotes; every extraction keeps the verbatim quote
Human accountability	Findings have owners and resolution notes; outreach has drafter and approver; nothing is sent automatically

Control	Implementation
Model change control	Model versions pinned; changes tested against the golden set before release; results recorded
No training on client data	Providers used under enterprise terms; opt-outs and zero- or limited-retention options selected where offered; self-hosting removes third parties entirely
Bias and language fairness	Evaluation set includes Arabic and English questions and documents; performance reported per language
Spend and abuse controls	Per-user and per-team budgets, rate limits and anomaly alerts on the gateway
Alignment with frameworks	Controls map to ISO/IEC 42001 (AI management) and the NIST AI Risk Management Framework; SDAIA's AI ethics principles are referenced for Saudi deployments

7. Compliance roadmap by tier

Tier	Evidence and certifications
Pilot	Security controls above; provider certifications (SOC 2, ISO 27001) for cloud services; data processing agreements in place
Departmental	Penetration test; documented policies; access reviews quarterly
Enterprise / sovereign	ISO 27001-aligned operations for the platform; alignment with Saudi NCA Essential Cybersecurity Controls or UAE Information Assurance standard as applicable; SIEM integration; customer-managed keys
Group-scale	Formal certification of the managed service; regular external audits; regulator engagement support

8. Responsibilities

Area	Client	Delivery team / managed service
Cloud account ownership and billing	Owns	Operates under delegated access
Identity provider and user lifecycle	Owns	Integrates
Data classification rules and lawful basis	Decides	Implements and enforces in software
Approval policies and approvers	Decides	Implements
Application security, patching, monitoring	Informed	Owns (managed service)
Incident response	Joint; client notified within agreed hours	Runs technical response
Regulatory filings and DPO duties	Owns	Provides evidence and reports

